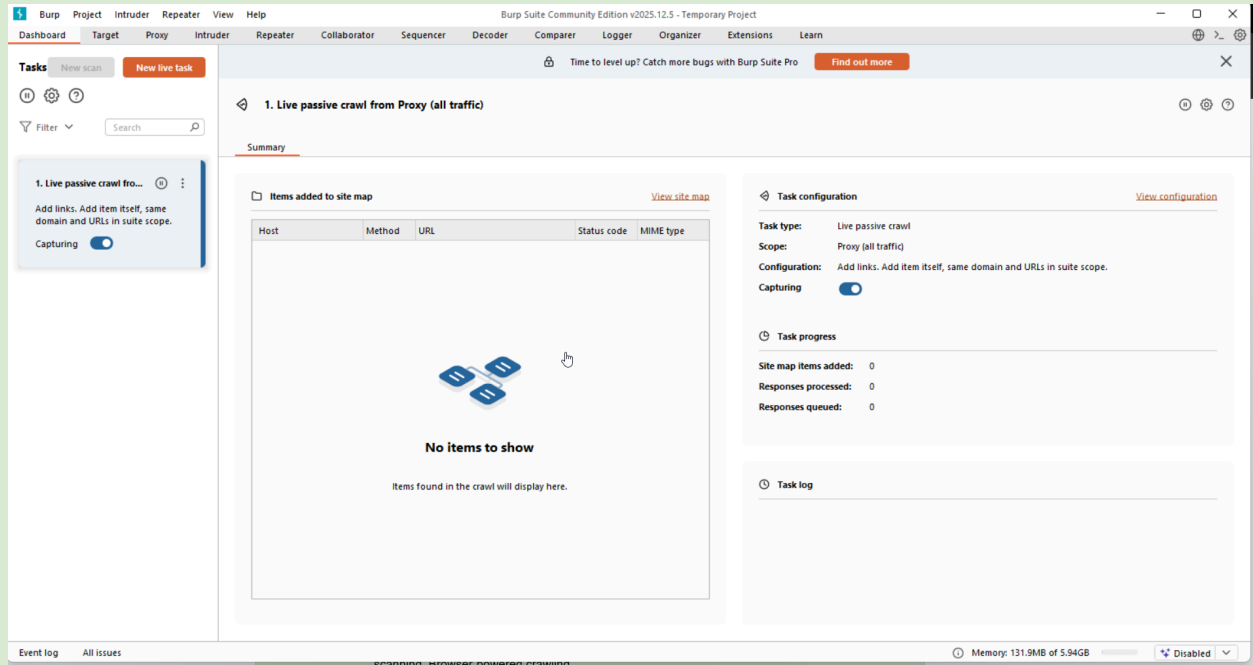


Burp Suite

Burp Suite is a leading integrated platform for **web application security testing**. It acts as an **intercepting proxy** that sits between your browser and the target application, allowing you to **inspect, modify, replay, and automate** HTTP/S requests and responses.

It is developed by **PortSwigger** (founded by Dafydd Stuttard).



Editions:

- **Burp Suite Community Edition** → Free, limited features (most used by beginners)
- **Burp Suite Professional** → Paid (full scanner, advanced automation, extensions, Collaborator, etc.)
- **Burp Suite Enterprise** → CI/CD integration for organizations

History:

- **2003–2004:** Dafydd Stuttard created Burp Proxy as a simple tool
- **2008–2010:** Evolved into full Burp Suite with Intruder, Repeater, Sequencer
- **2012–2015:** Scanner introduced (Pro), BApp Store launched
- **2016–2020:** Major updates – Project file format, Dashboard, Logger++, Turbo Intruder
- **2021–2025:** AI-assisted features, Burp 2.x (new UI), improved mobile testing, API scanning, Browser-powered crawling

Main Uses:

- Web application penetration testing
- API security testing
- Bug bounty hunting
- Vulnerability discovery & exploitation
- Session hijacking & token analysis
- Automated scanning (Professional)
- Manual testing & request crafting

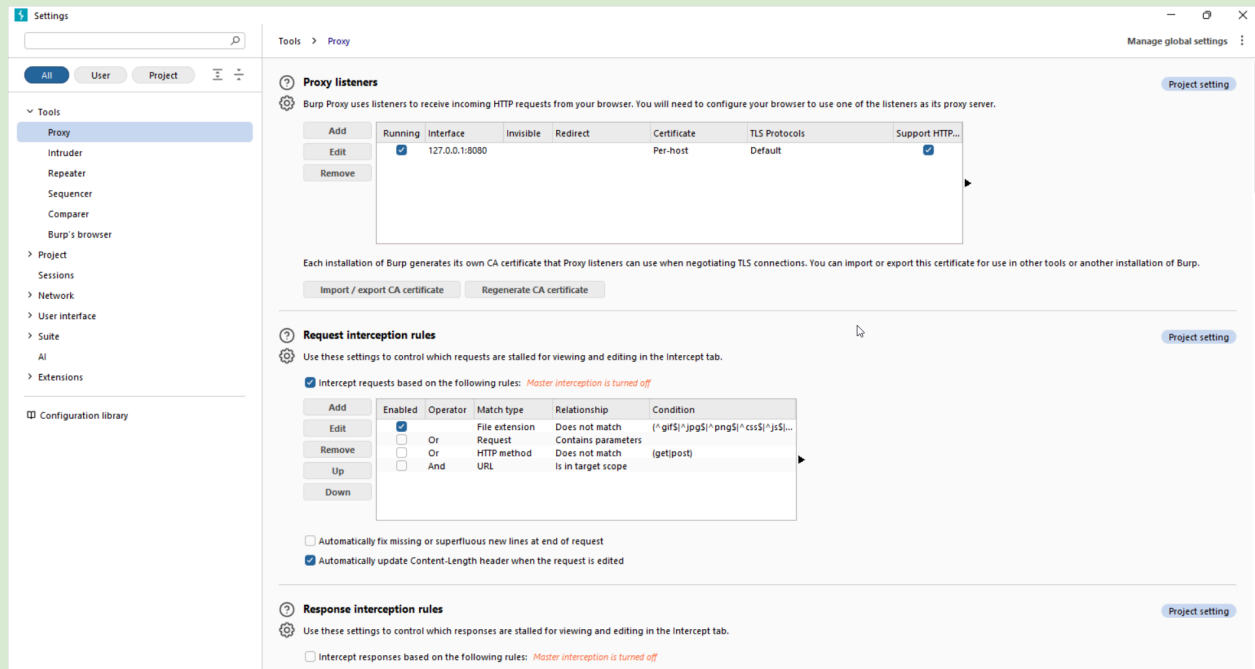
Key Components / Features:

1. Proxy (Core Feature)

Captures and intercepts all HTTP/S traffic.

The Proxy is the core of Burp Suite. It sits between your browser and the target application, allowing you to intercept, view, and modify all traffic.

- **Working Procedure (Intercept):**
 1. **Enable Intercept:** Go to the "Proxy" tab, then the "Intercept" sub-tab. Click the "Intercept is on" button.
 2. **Make a Request:** In your browser, navigate to a page or submit a form. The browser will hang.
 3. **Inspect Request:** The request is now paused in Burp. You can see the raw HTTP headers and body.
 4. **Modify and Forward:** You can edit any part of the request (e.g., change a parameter value). Click the "Forward" button to send the (potentially modified) request to the server.
- **Working Procedure (HTTP History):**
 1. **Disable Intercept:** Turn "Intercept is off" to browse normally.
 2. **Browse Application:** Burp logs all traffic in the background.
 3. **View History:** Go to the "HTTP history" sub-tab to see a table of all requests and responses.
 4. **Analyze and Send:** You can filter this list, select a request to view its full details, and right-click to send it to other tools like Repeater or Intruder.



Setup:

- Proxy listener: 127.0.0.1:8080
- Browser proxy settings → point to 127.0.0.1:8080
- Install Burp CA certificate (for HTTPS)

Example:

- Intercept login request
- Change password=admin123 → password=wrong
- Forward or drop request
- Modify User-Agent to test bot detection

2. Target Tab

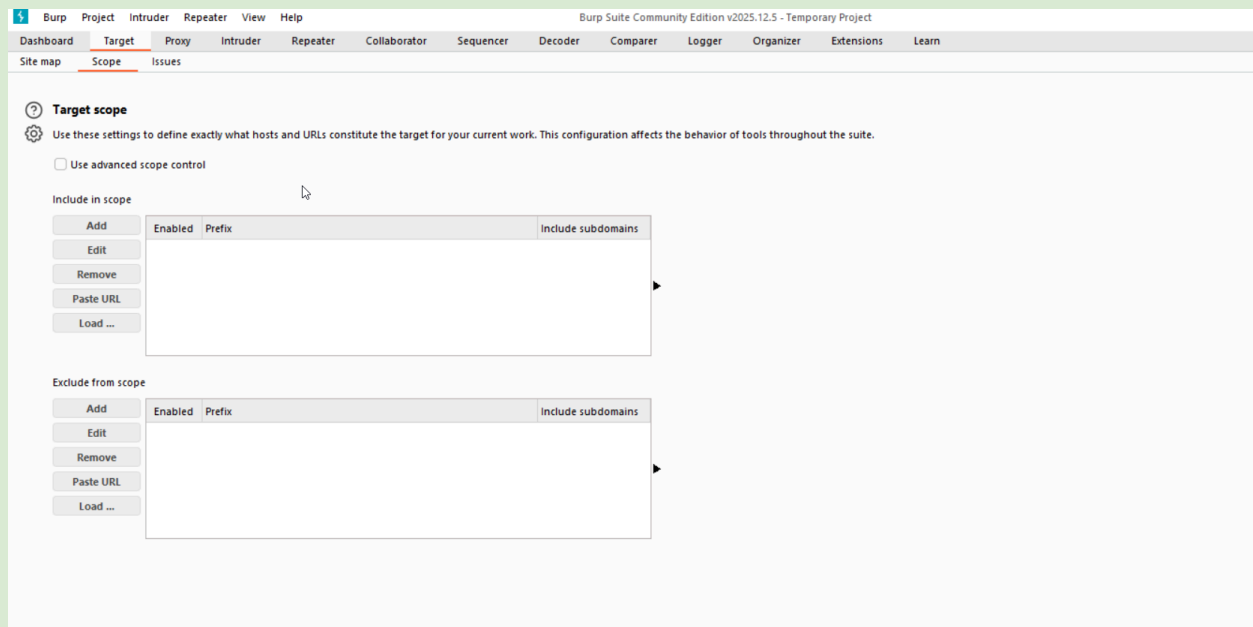
The Target tab is for reconnaissance. It helps you map out the application you're testing and define the boundaries of your engagement.

- **Working Procedure (Site Map):**

1. **Configure Proxy:** Ensure your browser is configured to send traffic through Burp's proxy.
2. **Browse the Target Website:** Navigate the Target website. As you visit pages, Burp automatically populates the "Site map" tab.
3. **View Structure:** The left pane shows a hierarchical tree of hosts, directories, and files.
4. **Analyze Requests:** Clicking an item in the tree shows all requests associated with it in the right pane.

- **Working Procedure (Scope):**

1. **Identify Target:** In the site map, find the domain you want to test.
2. **Add to Scope:** Right-click the domain or directory and select "Add to scope".
3. **Configure Scope:** Go to the "Scope" sub-tab to fine-tune your rules (e.g., include only specific subdomains or exclude logout pages). This filters your view and prevents Burp from sending requests to out-of-scope systems.

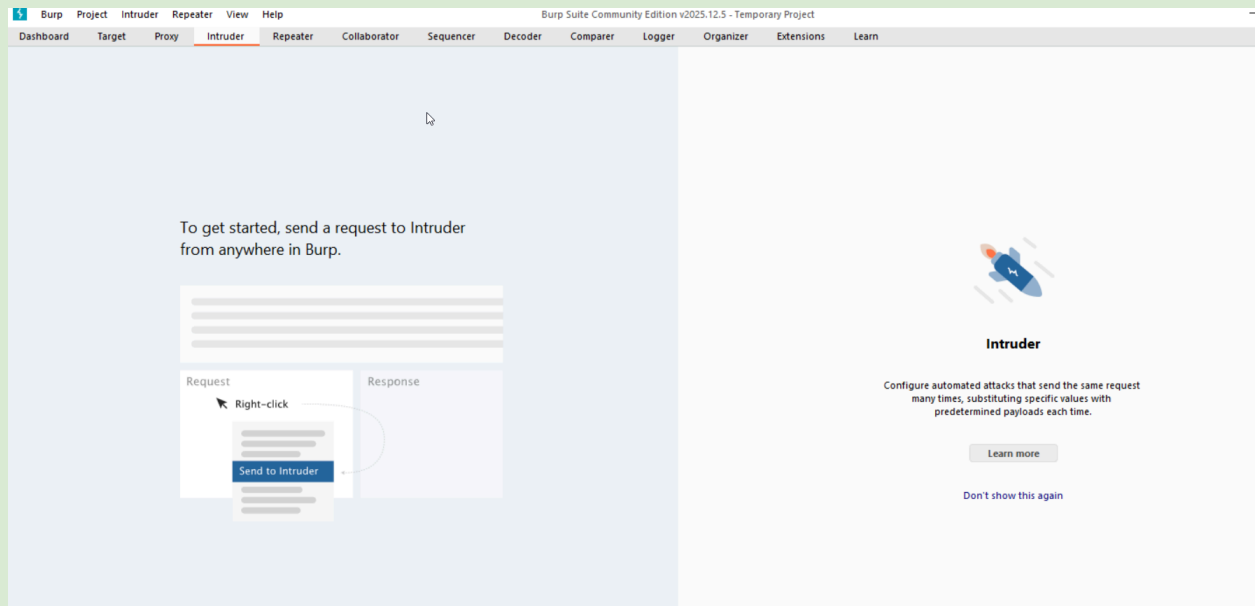


3. Intruder

Intruder is a powerful tool for automating customized attacks. It's used for tasks like brute-forcing passwords, fuzzing for vulnerabilities, and enumerating identifiers.

- **Working Procedure:**

1. **Send to Intruder:** Right-click a request in Proxy History or Repeater and select "Send to Intruder".
2. **Configure Positions:** In the "Positions" tab, Burp automatically highlights potential payload positions with § markers. You can add or remove these markers to specify exactly where you want to inject data.
3. **Set Payloads:** In the "Payloads" tab, define the data you want to inject. For a brute-force attack, you would select a "Simple list" payload type and paste a list of passwords.
4. **Start Attack:** Click the "Start attack" button. Burp will send a request for each payload.
5. **Analyze Results:** A new window opens showing a table of results. You can sort by status code or response length to find successful attempts or anomalies.



Example:

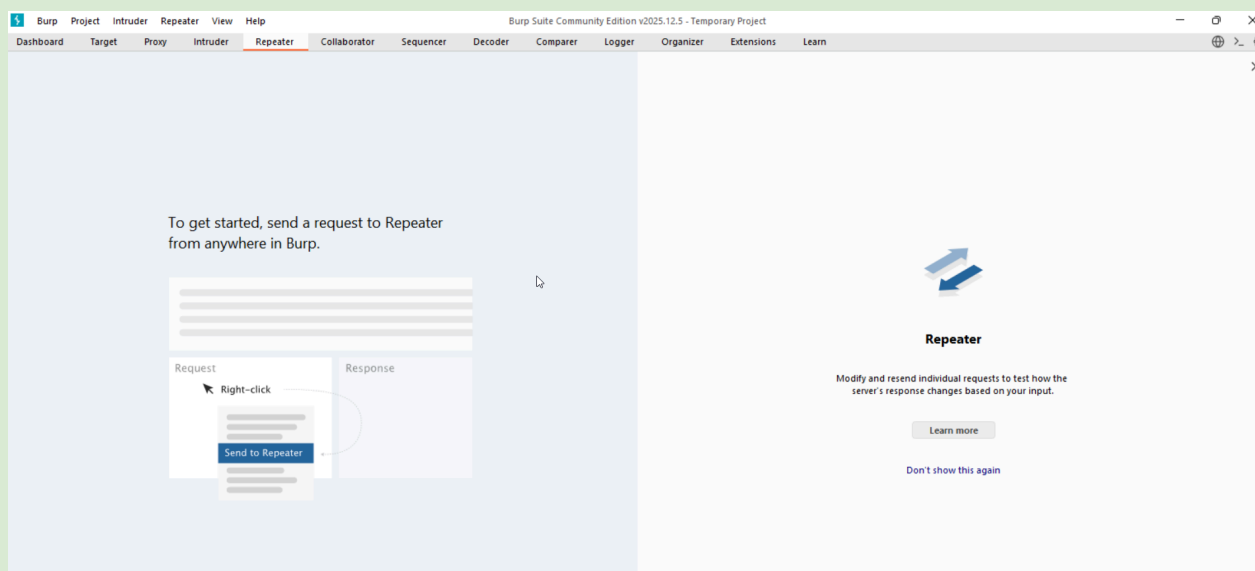
- Sniper attack on the password field using rockyou.txt
- Grep-Match: "Welcome" or "Dashboard"

4. Repeater (Most Used Manual Tool)

Repeater is a tool for manually modifying and resending individual requests. It's perfect for testing how an application handles different inputs without needing to use the browser.

- **Working Procedure:**

1. **Send to Repeater:** Send a request from Proxy History or another tool to Repeater.
2. **Modify Request:** In the left panel, you can freely edit the raw HTTP request. This includes headers, cookies, URL parameters, and the body.
3. **Send Request:** Click the "Send" button.
4. **View Response:** The server's response is displayed in the right panel. You can view it in "Raw", "HTML", or "Render" mode.
5. **Iterate:** You can modify the request again and click "Send" as many times as you like to test different scenarios.



Example:

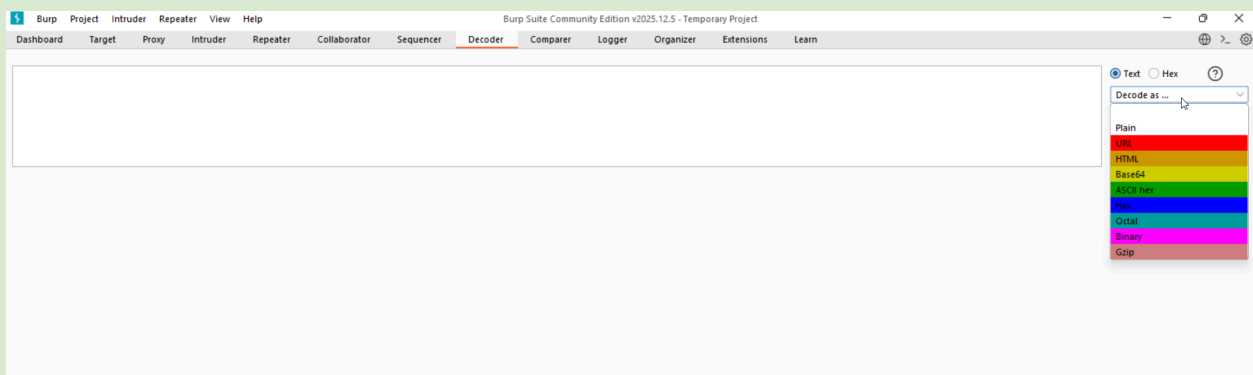
- Capture login request → Send to Repeater
- Change role=guest → role=admin
- Change cookie values
- Test SQLi: username=admin' OR '1'='1
- Test XSS: <script>alert(1)</script>

5. Decoder

Decoder is a simple but essential utility for encoding and decoding data in various formats common in web applications.

- **Working Procedure:**

1. **Input Data:** Paste the data you want to process into the top panel.
2. **Select Operation:** Click the "Decode as..." or "Encode as..." button.
3. **Choose Format:** Select the desired format from the menu (e.g., URL, HTML, Base64, Hex, Gzip).
4. **View Result:** The processed data appears in a new panel below. You can chain multiple operations together.



Example:

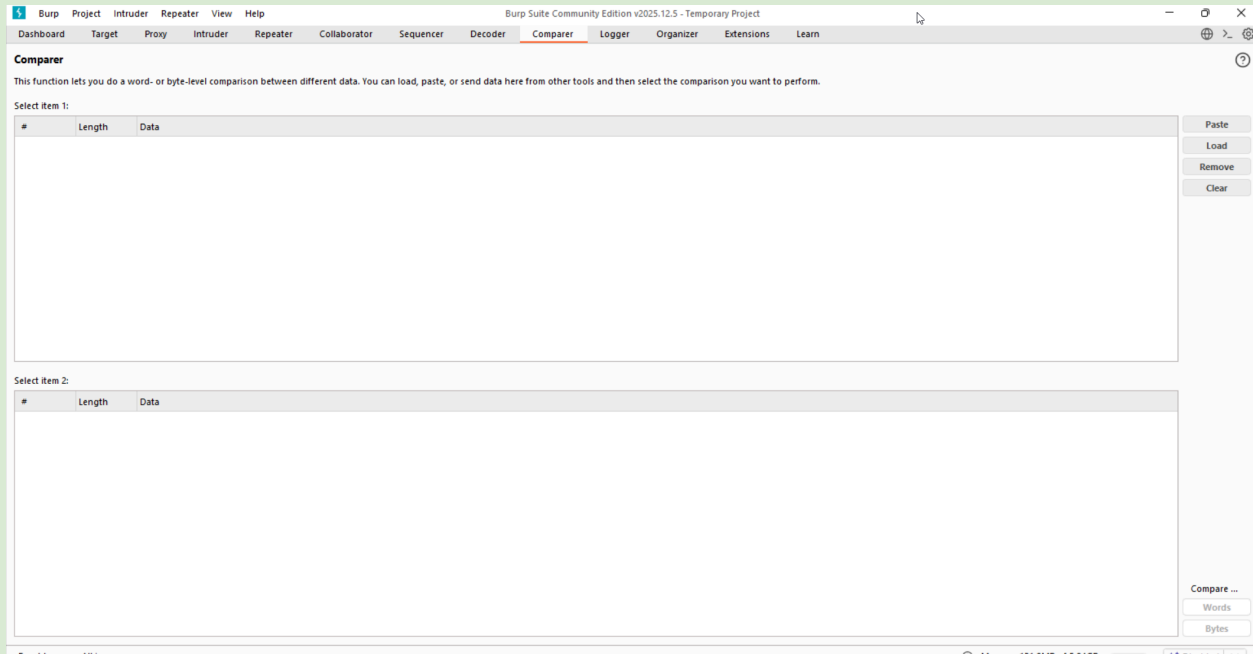
- Decode JWT token → modify payload → re-encode → test
- Convert URL-encoded payload to raw
- Hash strings (MD5, SHA-256)

6. Comparer

Comparer is a visual diff tool. It's used to compare two pieces of data, such as two similar HTTP requests or responses, to quickly identify differences.

- **Working Procedure:**

1. **Send Data:** Send two items to Comparer. You can do this by right-clicking them in Proxy History, Repeater, etc., and selecting "Send to Comparer".
2. **Select Items:** In the Comparer tab, select the two items you want to compare from the list.
3. **Start Comparison:** Click the "Words" or "Bytes" button to perform the comparison. "Words" is usually better for text-based data like HTML or JSON.
4. **Analyze Diff:** A new window opens showing the two items side-by-side. Differences are highlighted in color (e.g., added text in one color, removed text in another), making it easy to spot changes.

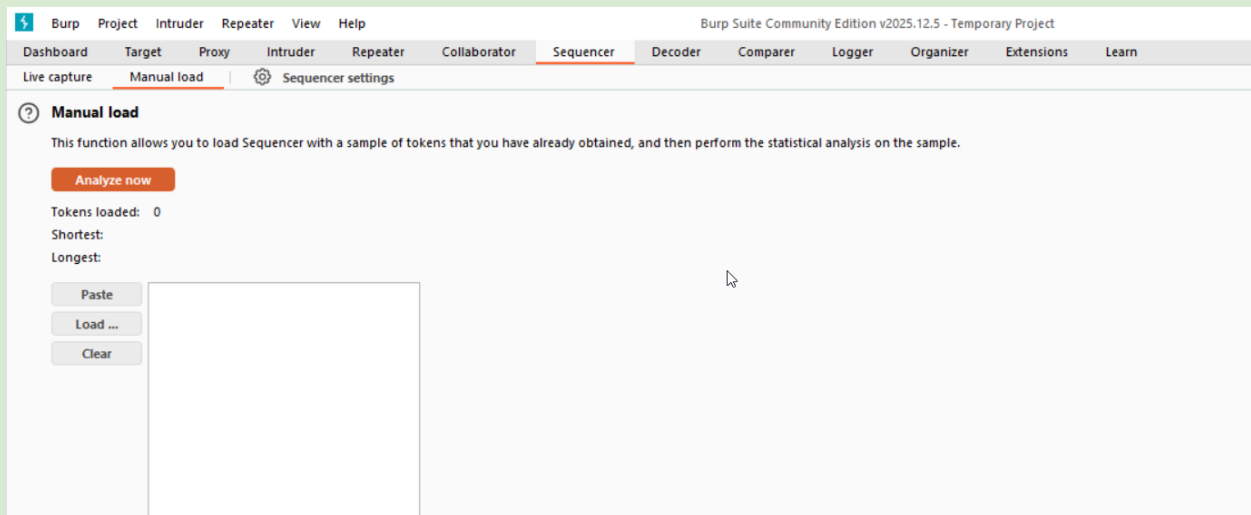


Example:

- Compare the response when logged in vs logged out
- Compare normal vs malicious request responses

7. Sequencer

Analyzes the randomness of session tokens/cookies.



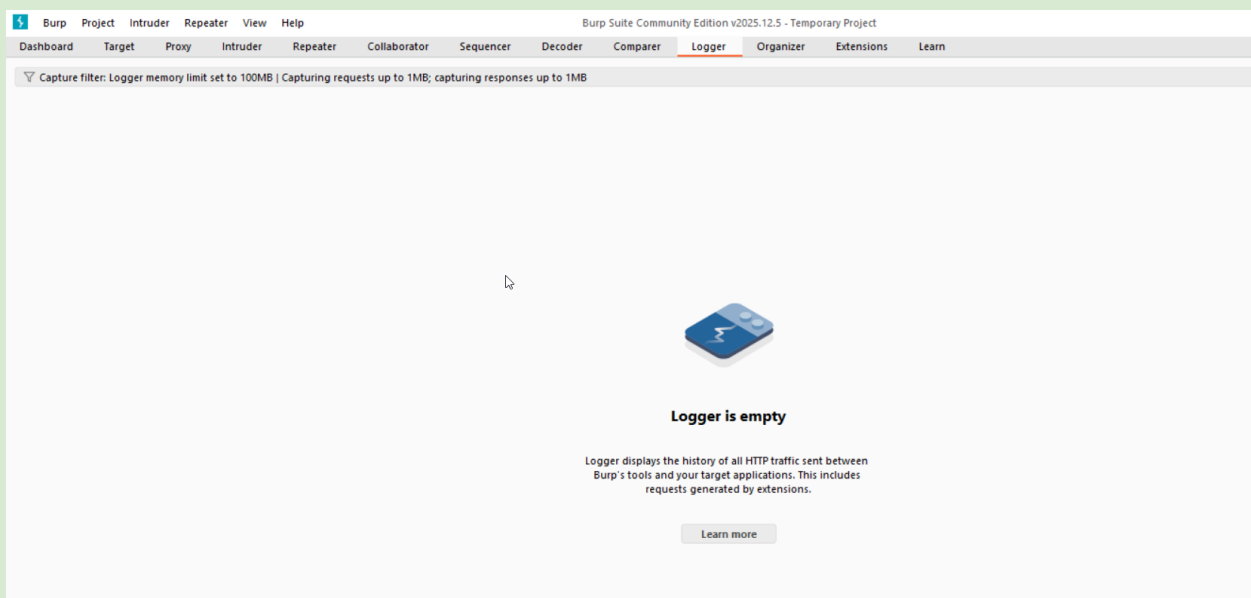
Example:

- Capture multiple session IDs
- Analyze entropy → detect predictable tokens

8. Logger

Logs all requests/responses (newer versions).

Use: Filter by status code, keyword, or domain



9. Scanner (Professional only)

The Scanner is an automated vulnerability scanner. It can crawl an application to find content and audit it for security flaws like SQL injection and cross-site scripting.

- **Working Procedure:**

1. **Initiate Scan:** You can start a scan in several ways. A common method is to right-click a host or request in the Target or Proxy tabs and select "Scan".
2. **Configure Scan:** A dialog box will appear where you can define the scan scope, select a scan configuration (e.g., "Crawl and Audit", "Audit selected items"), and set performance options.
3. **Monitor Progress:** The scan's progress is shown in the Dashboard's "Tasks" panel.
4. **Review Issues:** As vulnerabilities are found, they are listed in the "Issue activity" panel on the Dashboard. Click on an issue to see a detailed description, evidence, and remediation advice.

Types:

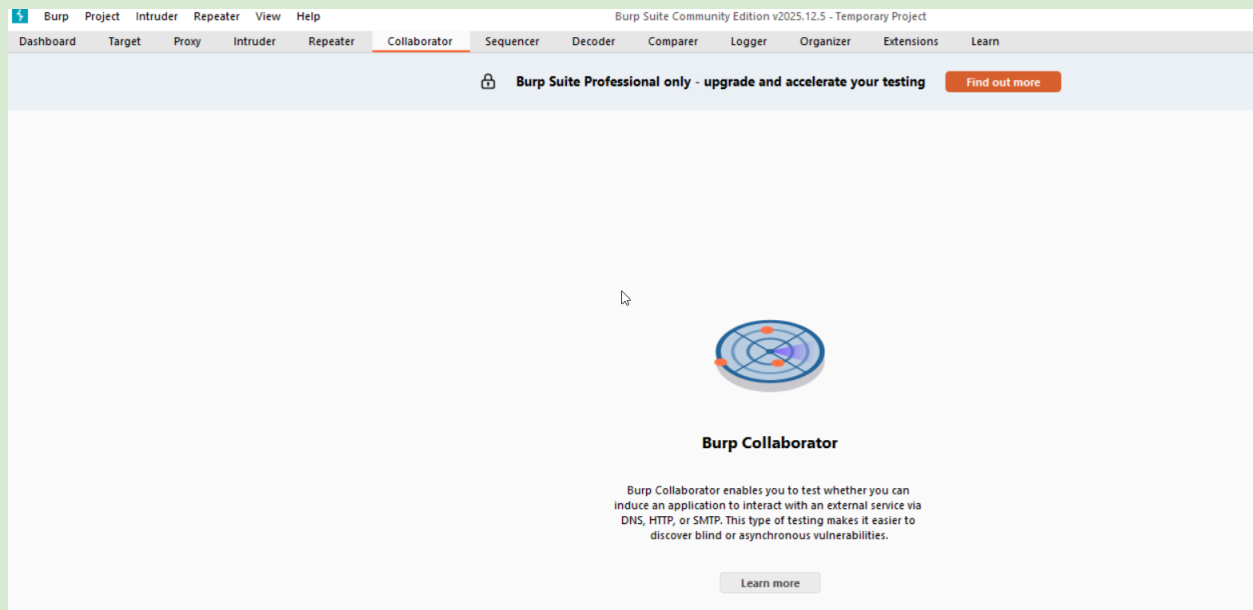
- Passive scanning (always on)
- Active scanning (crawls + attacks)

Example:

- Right-click target → Do active scan
- Finds XSS, SQLi, CSRF, IDOR, etc.

10. Collaborator (Professional)

Generates unique domains to detect out-of-band vulnerabilities (SSRF, blind XSS, blind SQLi).



Example:

- Payload: `http://abc123.oastify.com`
- Burp detects DNS/HTTP interaction

11. Extender (BApp Store)

Install extensions (Turbo Intruder, Authorize, Param Miner, etc.)

Extender allows you to customize and extend Burp's functionality using extensions written by the community or yourself.

- **Working Procedure:**
 1. **Browse BApp Store:** Go to the "Extender" tab, then the "BApp Store" sub-tab. This is a curated list of extensions.
 2. **Find Extension:** Browse or search for an extension that meets your needs (e.g., "Logger++" for better logging, "Retire.js" for finding vulnerable libraries).
 3. **Install:** Select the extension and click the "Install" button.
 4. **Use Extension:** Once installed, the extension may add new tabs to Burp, new menu options, or modify existing behavior. You can manage installed extensions in the "Extensions" sub-tab.

Popular Extensions:

- Authorize (auth bypass testing)
- Param Miner (hidden parameter discovery)
- HTTP Request Smuggler
- JWT Editor

12. Dashboard (Professional)

The Dashboard is your command center. It provides an at-a-glance view of your current tasks, automated scan results (in the Professional version), and general suite activity.

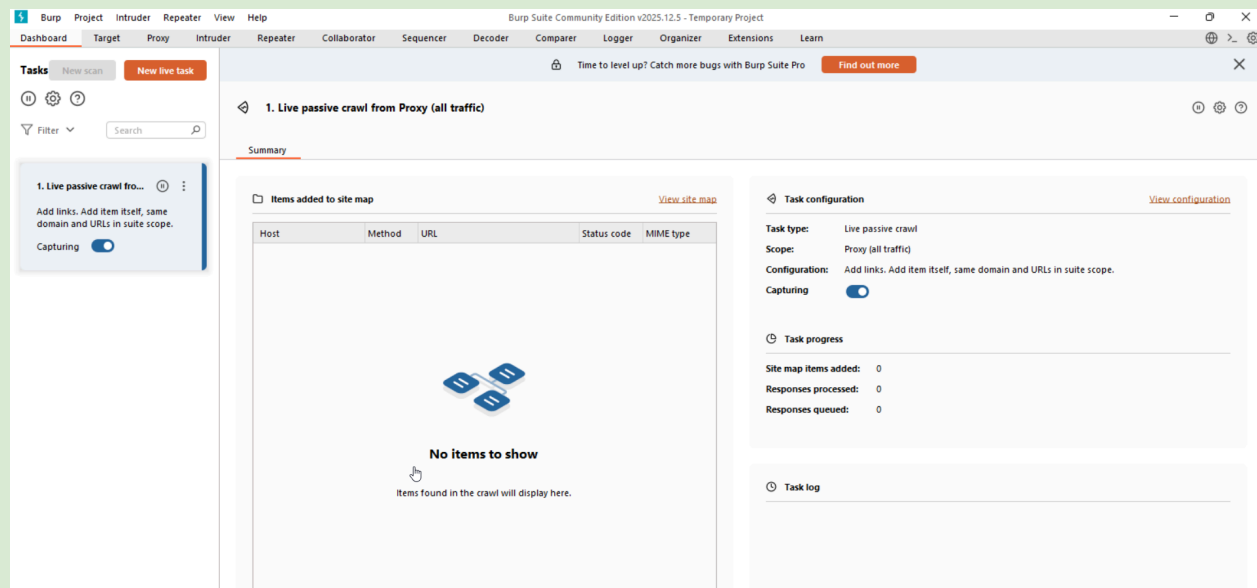
Working Procedure:

Open Burp Suite: The Dashboard is the default starting tab.

View Tasks: Observe the "Tasks" panel on the left. This will show the status of any active or completed crawls and audits.

Review Issues: The "Issue activity" panel in the center lists vulnerabilities found by the automated scanner. Click on an issue to see details.

Check Event Log: The "Event log" on the right records all significant Burp actions, errors, and information.



Differences from Other Tools:

Tool	Free Version	Scanner	Intruder	Proxy	Best For
Burp Suite	Yes	Paid	Yes	Yes	Manual + automation
OWASP ZAP	Fully free	Yes	Yes	Yes	Free automated scanning
Acunetix	No	Strong	Limited	Yes	Enterprise scanning
Nikto / Wfuzz	Yes	No	Limited	No	Quick recon/fuzzing
Browser DevTools	Yes	No	No	No	Basic debugging

Burp's advantage: Best balance between manual control and automation.

Basic Setup Workflow :

1. Download Burp Suite Community
2. Start Burp → Temporary project
3. Proxy → Options → Add listener (127.0.0.1:8080)
4. Install CA certificate in browser
5. Set browser proxy to 127.0.0.1:8080
6. Visit target → traffic appears in Proxy → HTTP history

Summary:

Burp Suite is the **industry standard** web application security testing tool.

It combines **manual testing power** (Proxy, Repeater, Decoder) with **automation** (Intruder, Scanner, Collaborator).

Most Important Tabs:

1. Proxy → intercept traffic
2. Repeater → manual testing
3. Intruder → brute-force/fuzzing
4. Target → site map & scope

Community Edition is sufficient for 80% of learning and bug bounty work.

Professional Edition adds automated scanning, Collaborator, and advanced features.

Key Takeaway:

Master **Proxy + Repeater + Intruder** first — these three features alone make you dangerous in web pentesting.